

MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Assessment Tool para Métricas Ciberseguridad-IA

Versión: 1.0 | **Fecha:** Enero 2026

Contexto: España | Indicadores Ciberseguridad IA

Metodología: 9 Criterios PRAGMATIC + Evidence Grid

INTRODUCCIÓN: CRITERIOS PRAGMATIC

Los 9 criterios PRAGMATIC (derivados de Glasgow et al. 2013, Battaglia et al. 2018, Hull et al. 2022) evalúan si una métrica es suficientemente **práctica, viable y valiosa** para implementación en organizaciones reales, no solo en contextos de laboratorio o investigación.

PRAGMATIC =

P: Predictivo	(predice outcome business/security real)
R: Relevante	(importa a stakeholders reales)
A: Accionable	(guía decisiones/acciones concretas)
G: Genuino	(mide outcome real, no proxy)
M: Significativo	(tiene peso material en strategy)
A: Preciso	(medible objetivamente)
T: Oportuno	(colectable en timeframe real)
I: Independiente	(no affected por factores externos)
C: Rentable	(ROI positivo, burden razonable)

SECCIÓN 1: ESCALA DE EVALUACIÓN (5 PUNTOS)

Escala Única para Todos Los Criterios

Score	Interpretación	Descripción
1	Poor	Criterio NO cumple; métrica no viable para implementación; friction severa
2	Fair	Criterio parcialmente cumple; implementación posible pero con challenges
3	Moderate	Criterio cumple adecuadamente; balance entre viabilidad y valor
4	Good	Criterio cumple bien; minor gaps; viable implementación
5	Excellent	Criterio cumple completamente; ideal para implementación inmediata

SECCIÓN 2: DEFINICIÓN OPERACIONAL 9 CRITERIOS PRAGMATIC

Criterio 1: PREDICTIVO (P)

Definición: ¿Predice la métrica outcomes de negocio/seguridad que importan? ¿Es forward-looking?

Evaluación Evidencia:

Score	Evidencia Requerida	Ejemplos Positivos	Ejemplos Negativos
1	No predice outcome; es puramente histórica	N/A	% parches aplicados históricos (sin link outcome)
2	Débil correlación empírica con outcomes	Audit findings sometimes linked to compliance	SIEM event volume (sin correlación breach)
3	Correlación moderada documentada; lagging indicator	MTTR tiene correlación documentada con breach cost	Training completion ≈ phishing resistance
4	Correlación fuerte; predictive de short-term	MTTD predice early incident detection; supported by data	Vulnerability MTTR predice unpatched exposure
5	Correlación fuerte + prospectiva; predictive forward	AI threat hunting predicts breach prevention proactively	Deepfake detection latency predicts comms compromise prevention

Scoring Guidance:

- Si métrica tiene estudios publicados de correlación: +1 punto
- Si correlación documentada internamente: +0.5 puntos
- Si es proxy imperfecta: -1 punto

Criterio 2: RELEVANTE (R)

Definición: ¿Importa la métrica a stakeholders reales? ¿Board, CISO, CTO la priorizan?

Evaluación Evidencia:

Score	Criterio	Stakeholder Alignment
1	Stakeholders no interesados; métrica ignoring	Interest <10%; not in board agenda
2	Limited stakeholder interest; niche concern	Interest 25%; mentioned pero no prioritized
3	Moderate interest; algunos stakeholders prioritize	Interest 50-60%; CTO + CISO interested pero no CEO
4	High interest; multiple stakeholders prioritize	Interest 75%+; CISO + CTO + Risk Head aligned
5	Critical to all stakeholders; board-level priority	Interest 90%+; CEO mandates; board reviews regularly

Scoring Guidance:

- Entrevista stakeholders clave; score basado en consenso
- Si métrica en regulatory requirement (NIS2, EU AI Act): +1 punto

Criterio 3: ACCIONABLE (A)

Definición: ¿Guían los scores decisiones/acciones concretas? ¿Hay threshold claro?

Evaluación Evidencia:

Score	Ejemplo Acción	Claridad
1	Score sin umbral claro; no hay acción impulsada	"MTTD is 48 hours" → sin decisión asociada
2	Acción vaga; múltiples interpretaciones posibles	"Low MTTD is good" → unclear what "low" means
3	Acción definida pero requiere interpretación contextual	"<24h MTTD → goal met; 24-48h → monitoring; >48h → escalate"
4	Acción clara; thresholds bien definidos; minor ambiguity	MTTD <2h → automated; 2-8h → review; >8h → failure; clear remediation path
5	Acción específica, automática; zero ambiguity	MTTD >24h triggers: (a) escalation ticket, (b) resource reallocation, (c) process audit

Scoring Guidance:

- Si score tiene decision tree clara: +1 punto
- Si acción es manual/interpretativa: -1 punto
- Si integrado en automated workflow: +1 punto

Criterio 4: GENUINO (G)

Definición: ¿Mide la métrica outcome real o es proxy imperfecta?

Evaluación Evidencia:

Score	Medida	Especificidad
1	Proxy muy débil; múltiples factores confounding	"# training hours" vs "phishing resistance"
2	Proxy imperfecta; factores externos dominan outcome	"Audit compliance score" vs "actual security posture"
3	Mide aspecto real pero no el outcome completo	"Click-rate phishing" mide susceptibility pero no comportamiento completo (no reporting)
4	Mide outcome real; minor confounding	"MTTR" mide actual respuesta tiempo pero affected by incident complexity
5	Mide outcome real directamente; no confounding	"Breach prevented" es outcome genuino; "models deployed" es métrica genuina de capacidad

Scoring Guidance:

- Outcome vs activity metric: outcomes siempre >3
- Si multiple factors confound: reducir score 1-2 puntos
- Si outcome medible directamente: score 4-5

Criterio 5: SIGNIFICATIVO (M - "Material")

Definición: ¿Tiene weight material en estrategia/risk? ¿O es cosmético?

Evaluación Evidencia:

Score	Impacto Material	Strategic Weight
1	Cosmético; sin impacto material	"# security patches" (cosmetic)
2	Minor impact; nice-to-have	"Employee training certificates completed"
3	Moderate impact; contribuye a objectives	"MTTR improved 20%" → contributes to risk reduction
4	Significant impact; core to strategy	"MTTD <24h" → directly enables incident containment
5	Critical impact; foundational estrategia	"Breach incidents prevented" → existential to organization

Scoring Guidance:

- Si métrica tied to regulatory requirement: +1 punto
- Si métrica tied to financial risk: +1 punto
- Si cosmético: máximo 2 puntos

Criterio 6: PRECISO (P - "Precise/Accurate")

Definición: ¿Es medible objetivamente? ¿O hay interpretación/subjetividad?

Evaluación Evidencia:

Score	Medición	Objetividad
1	Puramente subjetiva; sin estándar de medición	"Quality of security culture" (sin escala)
2	Mostly subjective; interpretación dominante	"Security maturity" (self-assessment bias)
3	Semi-objetiva; estándar existe pero room interpretación	"Risk score 1-10" (definition exists pero subjective judgment)
4	Mostly objective; timestamps/data en sistemas; minor measurement error	"MTTD" (logs timestamps; minor clock sync risk)
5	Completamente objective; data recolectable automáticamente	"Vulnerability remediation count" (ticketing system records directly)

Scoring Guidance:

- Si datos de automated system: +1 punto
- Si requiere manual entry: -1 punto
- Si ambigüedad en definición: -1 punto

Criterio 7: OPORTUNO (T - "Timely")

Definición: ¿Es colectable en timeframe real? ¿O requiere ciclos lentos?

Evaluación Evidencia:

Score	Disponibilidad Data	Timeframe
1	Data disponible anualmente o menos frequently	"Annual audit report" data
2	Data disponible trimestralmente	Quarterly compliance assessments
3	Data disponible mensualmente o al cierre ciclo	Monthly MTTD reports
4	Data disponible semanalmente o automáticamente	Weekly threat hunting summaries
5	Data disponible real-time o diariamente; automated pipeline	Real-time SIEM metrics

Scoring Guidance:

- Si automated: +1 punto

- Si manual monthly reporting: máximo 3 puntos
- Si annual cycle: máximo 2 puntos

Criterio 8: INDEPENDIENTE (I - "Independent")

Definición: ¿Es métrica independent de factores externos? ¿O vulnerable a shock externo?

Evaluación Evidencia:

Score	Dependencias	Control
1	Altamente dependent de factores externos no-controlables	"Breach incidents" (depends on attacker sophistication, luck)
2	Mostly dependent de factores externos	"MTTR" (depends on incident complexity, supply chain delays)
3	Parcialmente dependent; algunos factores controlables	"Vulnerability MTTR" (depends on patch vendor pero internal process controllable)
4	Mostly independent; internal factors dominate	"Training completion rate" (internal organizational control dominant)
5	Completamente independent; organizational control total	"Governance structure" (CISO reporting level is pure internal choice)

Scoring Guidance:

- Por cada dependencia externa no-controlable: -0.5 puntos
- Si factors external pero predictables: no penalize
- Si internal control >80%: score 4+

Criterio 9: RENTABLE (C - "Cost-Effective")

Definición: ¿ROI positivo? ¿Burden razonable vs. Outcome value?

Evaluación Evidencia:

Score	Costo	ROI
1	Costo muy alto; ROI negativo o unknown	SIEM deployment €2M annually; no clear breach prevention ROI
2	Costo alto; ROI marginal o 3+ años break-even	Threat hunting tool €400K; ROI 2-3 años
3	Costo moderado; ROI 1-2 años; marginal burden	Training simulation €80K; ROI 1 año
4	Costo razonable; ROI <1 año; low burden	MTTR tracking €50K tools; ROI <1 year (prevents incidents)
5	Costo bajo o embedded; ROI immediate/clear; minimal burden	Governance assessment €0 (internal only); infinite ROI if improves alignment

Scoring Guidance:

- Calcular TCO Year 1: tools + labor + infrastructure
- Calcular ROI: (prevented incident cost) - (TCO) / TCO
- Si ROI positive: 4-5 puntos
- Si ROI negative: 1-2 puntos

SECCIÓN 3: MATRIZ CONSOLIDADA EVALUACIÓN 9 INDICADORES

Formato: 9 Criterios × 9 Indicadores

Leyenda: 1=Poor | 2=Fair | 3=Moderate | 4=Good | 5=Excellent

Indica dor	P	R	A	G	M	P	T	I	C	AVG	Reco mend ación
1. AI- Threa t Detec tion	5	5	4	5	5	4	5	4	3	4.3	✓ IMPL EME NTAR
2. Vuln. Mana geme nt IA	4	5	5	5	5	4	5	3	4	4.4	✓ IMPL EME NTAR
3. Deepf ake Detec tion	3	4	4	4	4	3	3	2	2	3.1	⚠ SECO NDAR Y
4. SIEM +Hunt IA	5	5	5	4	5	4	5	3	4	4.4	✓ IMPL EME NTAR
5. Awar eness Traini ng	4	5	5	4	5	5	5	2	4	4.2	✓ IMPL EME NTAR
6. Comp liance NIS2/ AI	3	5	4	3	5	3	3	4	3	3.7	⚠ MAN DATE D
7. Suppl y Chain	5	5	4	5	5	4	3	3	3	4.0	⚠ PHAS E 2
8. Incide nt Respo nse	5	5	5	5	5	4	5	3	5	4.6	✓ IMPL EME NTAR

9. Gover nance	5	5	3	5	5	4	2	5	5	4.2	✓ FOUN DATI ON
----------------------	---	---	---	---	---	---	---	---	---	-----	-------------------------

SECCIÓN 4: ANÁLISIS DETALLADO POR INDICADOR

INDICADOR 1: AI-THREAT DETECTION (Score: 4.3)

AI-THREAT DETECTION PRAGMATIC SCORECARD		
P (Predictivo):		5/5
R (Relevante):		5/5
A (Accionable):		4/5
G (Genuino):		5/5
M (Significativo):		5/5
P (Preciso):		4/5
T (Oportuno):		5/5
I (Independiente):		4/5
C (Rentable):		3/5
PROMEDIO:		4.3/5
EVALUACIÓN:	ALTAMENTE PRAGMÁTICA	
RECOMENDACIÓN:	✓ IMPLEMENTAR INMEDIATAMENTE	

Hallazgos Clave:

- **Fortalezas:** Predicción robusta (MTTD reduction = breach cost reduction); relevancia universal; oportuno (real-time SIEM data)
- **Debilidad:** Rentabilidad marginal (SIEM investment €180K annually); dependencia attacker sophistication
- **Acción:** Presupuestar SIEM modernization €200K Year 1; ROI >€1M si incident prevented

INDICADOR 2: VULNERABILITY MANAGEMENT IA (Score: 4.4)

VULNERABILITY MGT PRAGMATIC SCORECARD		
P (Predictivo):		4/5
R (Relevante):		5/5
A (Accionable):		5/5
G (Genuino):		5/5
M (Significativo):		5/5
P (Preciso):		4/5
T (Oportuno):		5/5
I (Independiente):		3/5
C (Rentable):		4/5
PROMEDIO:		4.4/5
EVALUACIÓN:	ALTAMENTE PRAGMÁTICA	
RECOMENDACIÓN:	✓ IMPLEMENTAR INMEDIATAMENTE	

Hallazgos Clave:

- **Fortalezas:** Accionable clara (SLA thresholds); medible objetivamente; ROI positivo
- **Debilidad:** Independencia limitada (patch vendor delays, system complexity)
- **Acción:** Presupuestar herramientas remediation automatización €200K; target MTTR <15 días

INDICADOR 3: DEEPFAKE DETECTION (Score: 3.1)

DEEPFAKE DETECTION PRAGMATIC SCORECARD		
P (Predictivo):		3/5
R (Relevante):		4/5
A (Accionable):		4/5
G (Genuino):		4/5
M (Significativo):		4/5
P (Preciso):		3/5
T (Oportuno):		3/5
I (Independiente):		2/5
C (Rentable):		2/5
PROMEDIO:		3.1/5
EVALUACIÓN:	MODERADAMENTE PRAGMÁTICA	
RECOMENDACIÓN:	⚠ IMPLEMENTAR FASE 2 (2027)	

Hallazgos Clave:

- **Fortalezas:** Relevante para comunicaciones críticas; medible accuracy
- **Debilidades Significativas:**
 - Rentabilidad pobre (sistemas €500K+; high operational friction)
 - Independencia baja (modelo accuracy affected by deepfake generation sophistication)
 - Oportuno limitado (multi-modal detection still manual-intensive)
- **Acción:** Monitoring tecnología 2026; implementación 2027 cuando herramientas maduras

INDICADOR 4: SIEM+THREAT HUNTING IA (Score: 4.4)

SIEM+HUNTING PRAGMATIC SCORECARD		
P (Predictivo):		5/5
R (Relevante):		5/5
A (Accionable):		5/5
G (Genuino):		4/5
M (Significativo):		5/5
P (Preciso):		4/5
T (Oportuno):		5/5
I (Independiente):		3/5
C (Rentable):		4/5
PROMEDIO:		4.4/5
EVALUACIÓN:	ALTAMENTE PRAGMÁTICA	
RECOMENDACIÓN:	✅ IMPLEMENTAR INMEDIATAMENTE	

Hallazgos Clave:

- **Fortalezas:** Predicción robusta (proactive detection); automatable; ROI positivo

- **Debilidad:** Independencia (threat hunting effectiveness affected by attacker sophistication)
- **Acción:** Presupuestar threat hunting platform + 2-3 FTE €400K annually

INDICADOR 5: AWARENESS TRAINING (Score: 4.2)

AWARENESS TRAINING PRAGMATIC SCORECARD		
P (Predictivo):		4/5
R (Relevante):		5/5
A (Accionable):		5/5
G (Genuino):		4/5
M (Significativo):		5/5
P (Preciso):		5/5
T (Oportuno):		5/5
I (Independiente):		2/5
C (Rentable):		4/5
PROMEDIO:		4.2/5
EVALUACIÓN:	ALTAMENTE PRAGMÁTICA	
RECOMENDACIÓN:	✓ IMPLEMENTAR INMEDIATAMENTE	

Hallazgos Clave:

- **Fortalezas:** Medible automáticamente; bajo costo; accionable
- **Debilidad:** Independencia (employee behavior subject to fatigue, context, attention)
- **Acción:** Presupuestar simulación + training platform €80K; target click-rate <5%

INDICADOR 6: COMPLIANCE NIS2/AI ACT (Score: 3.7)

COMPLIANCE PRAGMATIC SCORECARD		
P (Predictivo):		3/5
R (Relevante):		5/5
A (Accionable):		4/5
G (Genuino):		3/5
M (Significativo):		5/5
P (Preciso):		3/5
T (Oportuno):		3/5
I (Independiente):		4/5
C (Rentable):		3/5
PROMEDIO:		3.7/5
EVALUACIÓN:	MODERADAMENTE PRAGMÁTICA	
RECOMENDACIÓN:	⚠ IMPLEMENTAR (MANDATED)	

Hallazgos Clave:

- **Fortalezas:** Mandated (NIS2, EU AI Act); relevancia universal; independent
- **Debilidades:** Lagging indicator (no predicts future breach); imperfect proxy for actual security
- **Acción:** Compliance tracking obligatorio pero no como primary metric; complementar con outcome-based metrics

INDICADOR 7: SUPPLY CHAIN (Score: 4.0)

SUPPLY CHAIN PRAGMATIC SCORECARD		
P (Predictivo):		5/5
R (Relevante):		5/5
A (Accionable):		4/5
G (Genuino):		5/5
M (Significativo):		5/5
P (Preciso):		4/5
T (Oportuno):		3/5
I (Independiente):		3/5
C (Rentable):		3/5
PROMEDIO:		4.0/5
EVALUACIÓN:	PRAGMÁTICA (CON CAVEATS)	
RECOMENDACIÓN:	⚠ FASE 2 (Q4 2026 - Q1 2027)	

Hallazgos Clave:

- **Fortalezas:** Predicción excelente (SBOM verificación previene supply chain breach); significativo
- **Debilidades:** Friction operacional (vendor cooperation needed); oportuno limitado (SBOM generation manual)
- **Acción:** Evaluar herramientas SBOM automática 2026; deployment 2027

INDICADOR 8: INCIDENT RESPONSE IA (Score: 4.6)

INCIDENT RESPONSE PRAGMATIC SCORECARD		
P (Predictivo):		5/5
R (Relevante):		5/5
A (Accionable):		5/5
G (Genuino):		5/5
M (Significativo):		5/5
P (Preciso):		4/5
T (Oportuno):		5/5
I (Independiente):		3/5
C (Rentable):		5/5
PROMEDIO:		4.6/5
EVALUACIÓN:	ALTAMENTE PRAGMÁTICA	
RECOMENDACIÓN:	✅ IMPLEMENTAR INMEDIATAMENTE	

Hallazgos Clave:

- **Fortalezas:** Máximo score en 7 de 9 criterios; ROI masivo (MTTR reduction = cost avoidance)
- **Debilidad Única:** Independencia (incident complexity affects MTTR)
- **Acción:** **PRIORIDAD MÁXIMA.** Presupuestar SOAR + playbooks automáticos €300K Year 1; target MTTR <30 min

INDICADOR 9: GOVERNANCE (Score: 4.2)

GOVERNANCE PRAGMATIC SCORECARD		
P (Predictivo):		5/5
R (Relevante):		5/5
A (Accionable):		3/5
G (Genuino):		5/5
M (Significativo):		5/5
P (Preciso):		4/5
T (Oportuno):		2/5
I (Independiente):		5/5
C (Rentable):		5/5
PROMEDIO:		4.2/5
EVALUACIÓN:	ALTAMENTE PRAGMÁTICA	
RECOMENDACIÓN:	✓ FOUNDATION (IMPLEMENTAR 1ER)	

Hallazgos Clave:

- **Fortalezas:** Predictivo governance (governance → investment → capability); independent
- **Debilidades:** Accionable limitado (requires executive decision); oportuno (annual cycles)
- **Acción:** **IMPLEMENTAR PRIMERO.** Governance es prerequisite para todas otras iniciativas; no cost; maximum ROI

SECCIÓN 5: RECOMENDACIONES FINALES

Matriz Priorización por PRAGMATIC Score

Fase	Indicadores	Avg Score	Timeline	Budget
1 - Foundational	Governance (9)	4.2	Immediate	€0 (internal)
2 - Crítica Immediate	AI-Detection (1), Vuln.Mgmt (2), SIEM (4), Training (5), IR (8)	4.3-4.6	Q1 2026	€1.2M Year 1
3 - Mandated	Compliance (6)	3.7	Q2 2026	€150K Year 1
4 - Strategic Secondary	Deepfake (3)	3.1	Q4 2026-Q1 2027	€500K Year 1
5 - Advanced	Supply Chain (7)	4.0	Q4 2026-Q1 2027	€350K Year 1

FIN DE MATRIZ PRAGMATIC COMPLETA